코디세이 Final-Project · 기업 PBL 비상테크 「사내 P2P 파일 공유 서비스」

SafeDrop

보내기 직전에 한 번 더 확인하는 사내 파일 전송 채널

팀 codev

주시호(팀장) · 양원석 · 육민호 · 이태우 · 최시원

01 · 문제

보내는 실수로 생기는 유출

해킹이 아니라 '이 파일을 이 사람에게 보내도 되는가'를 묻지 않아 생긴 유출

25~30%

국내 개인정보 유출 신고 중 **업무 과실**의 비율

단체 채팅방 게시 · 이메일 동보 발송 · 잘못 첨부

2024년 307건 중 91건, 2025년 447건 중 110건
출처: 개인정보보호위원회·KISA 「개인정보 유출 신고 동향」

받는 사람마다 다른 허용 범위
인사팀은 원본, 다른 부서는 가린 사본, 협력사는 금지

문장 속 민감정보
"○○ 과장 공황장애 진단"은 번호 형식 도구로 잡히지 않음

망분리 완화 (N2SF, 2025.9)
"망이 나뉘어 안전하다"는 전제가 약해져 파일 단위 판단이 필요

02 · 해결

받는 사람마다 다른 처리

같은 파일의 원본 · 가린 사본 · 차단 구분과 사내 규정 조항 근거 설명



인사기록카드 **1개**, 받는 사람 **4명** → 결과 3가지

받는 사람별 규칙 없이 부서와 권한 네 가지 정보만으로 자동 분류

구분	일반적인 DLP	SafeDrop
결과	정책에 따라 차단·경고	같은 파일을 받는 사람마다 원본 / 가린 사본 / 차단
설명	정책 안내 문구	규정 조항 근거 설명 + 원문에서 고칠 위치 표시
전송	기존 메일·메신저 경로 감시	전송 채널 자체 + 받는 쪽 브라우저가 서명 검증

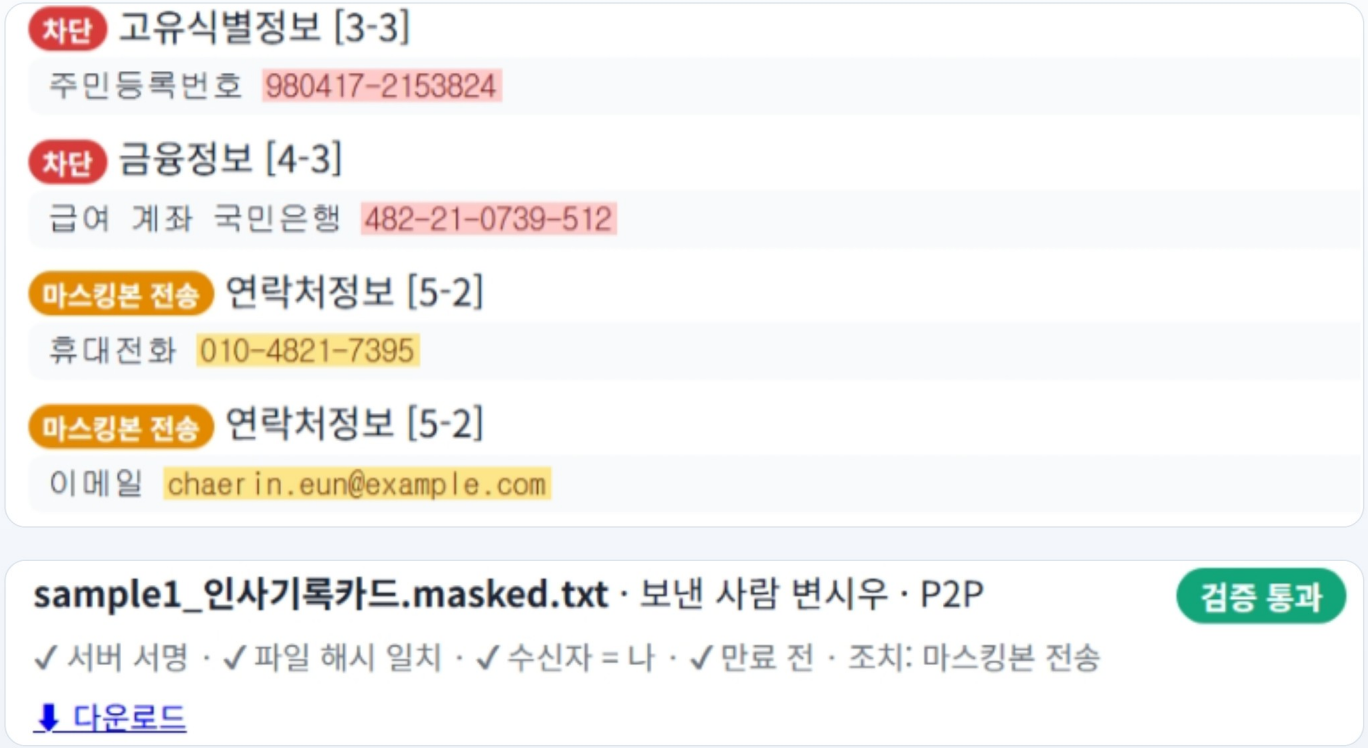
시연: 인사기록카드 보내기

영업팀 변시우가 신규 입사자 인사기록카드를 4명에게 보내는 상황

시연 순서

1. 4명에게 검사 → 수신자별 결과
2. 협력사 차단 원인 위치 보기
3. 전송 → 받는 쪽 검증 ✓4
4. 받은 마스킹본 열어 보기

safedrop-7sx9.onrender.com



03 · 시연

시연: 회의록 속 건강 정보

번호가 하나도 없는 문서 속 민감정보 문장의 탐지와 차단

차단 민감정보 [6-3]

2. 인력 현황: 편서준 대리는 지난달 허리디스크 수술을 받아 이번 주까지 병가 중이며, 다음 주 월요일 복귀 예정이다.

마도현 · 인사팀 (개인정보취급자) — 원본 허용

길하람 · 영업팀 (같은 부서) — 마스킹본 전송

탁운재 · 개발팀 (다른 부서) — 차단

정규식만으로는 **0건** → 사람 이야기 문장만 골라 AI가 판단

AI가 든 근거 문구가 원문에 실제로 있는지 코드가 대조

04 · 설계

AI에게 결정을 맡기지 않는 구조

판정은 규칙표, AI는 판단과 설명, 검증은 코드

1단계
탐지
번호는 정규식과 문맥
문장은 AI가 판단

2단계
판정
규칙표 20칸이 결정
AI 관여 없음

3단계
설명
조항 검색 후 AI 설명
인용은 코드가 검증

4단계
전송
서버가 서명한 토큰
받는 쪽이 검증

개발 과정도 같은 원칙 · AI 코딩 도구로 만들고, 팀원이 만든 데이터와 측정으로 검증

AI 출력이 검증을 통과하지 못하면 막는 쪽으로 처리 (fail-closed)

05 · 측정

측정으로 고른 네 가지

개발자가 아닌 팀원이 만든 테스트 데이터로 비교한 개선 전후

측정 항목	개선 전	개선 후	그래서 고른 것
정형 개인정보 정밀도	69%	96%	정규식 + 문맥 판단
문장 속 민감정보 재현율	0% (정규식)	100%	후보 문장만 AI 판단
AI 설명 대기 시간	35초	2.4초	판단·설명 모델 분리
로컬 LLM 판단 정확도	14B 80%	8B 90%	8B급 2개 조합

외부 API 없이 GPU 16GB 1대의 로컬 LLM으로도 같은 수준의 결과

SafeDrop · 팀 codev · 정형 탐지 문서 28개(정답 76개), 민감 문장 20개, 조항 검색·설명 20개 상황

06 · 검증

사용자 테스트와 반영

팀원이 아닌 다섯 명의 사용자 · 직장인 2명, 학생 3명

4.8 / 5

"서비스의 판단이 납득되었다"

근거 설명 4.6 · 사용 편의 4.8
마스킹본으로 업무 가능 4.8 · 사용 의향 4.6

"협력사에게는 어떤 결과?" **5명 모두 정답**

피드백 → 반영

"어디 때문에 막혔는지 보고 싶다" (2명)

→ 수신자별 원인 위치 보기 추가

"P2P 전송 실패" (1명)

→ 실제로는 서버 중계로 전송 성공 · 문구를 '전송 완료'로 수정

07 · 협업

역할 분담과 협업 방식

기획은 팀 전원, 개발 이후에는 서로 다른 사람이 확인하는 구조

담당	맡은 일	결과물 (GitHub 기록)
팀 전원	기획	주제 선정 투표, 기획서, 서비스 방향
주시호	설계·구현·배포, 측정	서비스 코드 (AI 코딩 도구 활용), PR 리뷰
최시원	정형 개인정보 테스트 데이터	테스트 문서 20개 + 정답 (PR #4)
이태우	함정·검증용 테스트 데이터	함정 문서 7개 + 정답, 과적합 점검 (PR #2)
육민호	문맥형 민감정보 데이터	민감정보 문장 20개, 경계 사례 설계 (PR #1)
양원석	사용자 테스트, 로컬 LLM 측정	시나리오·설문·모집, 측정 2회 (PR #3·5·6)

만든 사람이 자기가 예상한 경우만 확인하고 넘어가는 일을 방지 · PR 6개 리뷰·병합, Issue 2개

08 · 적용

실제 적용 가능성

회사마다 바꿀 것은 규정과 조직도뿐인 구조

폐쇄망 설치

외부 API 없이 GPU 16GB 1대 사내 서버, 설치 묶음 준비

규정만 교체

조항 번호를 붙인 규정과 규칙표 20칸, 코드 수정 없음

사람 등록

직원 1명당 정보 4가지, 입사·이동 때만 갱신

실제로 도입한다면 다음 과제 · 사내 계정 연동과 예외 승인 흐름

보내기 직전의 한 번 확인으로, 실수가 유출이 되지 않도록 하는 것.
이것이 SafeDrop의 역할입니다.

감사합니다

Q&A

GitHub
github.com/jutopia03/safedrop

서비스
safedrop-7sx9.onrender.com

팀 codev

부록 A1

측정 상세

버전별 수치와 과적합 점검, 측정의 한계

항목 (데이터)	베이스라인	최종
정형 탐지 (문서 28개, 정답 76개)	재현율 87% · 정밀도 69%	95% · 96%
↳ 개선에 쓰지 않은 문서만	정밀도 58%	94%
문장 속 민감정보 (20문장)	정규식만 재현율 0%	재현율 100% · 정밀도 86%
근거 조항 검색 (20개 상황)	Recall@3 90%	100%
AI 설명 인용 검증 (20개 상황)	보완 후 25%로 악화	원인 수정 후 20/20
AI 설명 대기 시간	35.4초	2.4초

AI 설명 개선

개선 전: 조항 문장 4개를 그대로 나열
개선 후: 2문장 (결과와 이유 / 할 일), 조항은 번호만 표시

한계

데이터가 수십 건 규모 · 규정이 작은 문서라 검색 수치가 높게 나옴 · 남은 탐지 오류의 절반 이상은 OCR 오인식

부록 A2

보안 설계

화면 결과 대신 서버 재판정과 받는 쪽 검증에 기반한 전송

전송 허가 토큰 · 전송 직전 서버가 재판정 후 ECDSA P-256 서명, 10분 유효

서버 중계 · P2P 실패 시 메모리에 10분, 1회 수신 후 삭제

감사 로그 · 파일 내용 없이 누가·누구에게·어떤 조치·근거 조항만 (다음 장)

받는 쪽 검증 4가지 · 서버 서명 · 파일 해시 · 수신자 = 나 · 만료 전

프롬프트 인젝션 · 지시문이 의심되면 AI 판단을 쓰지 않고 민감정보로 간주



부록 A2

감사 로그

정보보호 관리자 전용 · 파일 내용 없이 메타데이터만 기록 (규정 8-1)

시각 (한국)	이벤트	발신	수신	파일	내용
11-07 19:14:11	login	표준혁			
11-07 19:14:01	received		탁운재		검증 통과 (P2P)
11-07 19:14:01	relayed	표준혁	길하람	sample1_인사기록카드.masked.txt	
11-07 19:14:01	relayed	표준혁	마도현	sample1_인사기록카드.docx	
11-07 19:14:00	blocked	표준혁	봉태경	sample1_인사기록카드.docx	근거 3-3, 4-3, 5-2
11-07 19:14:00	approved	표준혁	탁운재	sample1_인사기록카드.masked.txt	근거 3-2, 4-2, 5-1
11-07 19:14:00	approved	표준혁	길하람	sample1_인사기록카드.masked.txt	근거 3-2, 4-2, 5-1
11-07 19:14:00	approved	표준혁	마도현	sample1_인사기록카드.docx	근거 3-1, 5-1, 4-1

부록 A3

로컬 LLM 측정

외부 클라우드를 못 쓰는 회사를 위한 폐쇄망 구성 · RTX 4080 SUPER 16GB

모델	실행 위치	민감정보 판단 정확도	AI 설명 통과	GPU 메모리
gpt-5-mini	외부 API	90%	—	—
gpt-5.4-mini	외부 API	—	20/20	—
qwen3:8b	로컬	90% (틀린 문장까지 동일)	15/20	5.6GB
exaone3.5:7.8b	로컬	85%	18~20/20	5.2GB
qwen3:14b	로컬	80% (1차)	11/20 (1차)	9.5GB

권장: 판단 qwen3:8b + 설명 exaone3.5 → 약 11GB, GPU 16GB 1대에 함께 적재

부록 A4

시스템 구성

브라우저 · SafeDrop 서버 · 사내 데이터 · LLM의 연결

발신자 브라우저

파일 업로드
수신자 선택
결과·설명 확인

SafeDrop 서버 (FastAPI)

① 텍스트 추출
(스캔은 OCR)

② 정규식 탐지
+ AI 문맥 판단

③ 규칙표 판정

④ 마스킹 사본

⑤ 조항 검색
+ AI 설명·검증

⑥ 허가 토큰
(ECDSA 서명)

로그인·세션 · P2P 신호 전달 · 중계(10분) · 감사 로그

수신자 브라우저

토큰 검증 4가지
통과 시 다운로드

사내 데이터 (파일로 분리)

조직도 · 판정 규칙표 · 규정 조항 → 회사가 바뀌면 이것만 교체

LLM (OpenAI 호환)

코디세이 API 또는 사내 Ollama → 주소만 바꿔 교체

파일 본문은 발신자 → 수신자 브라우저 직접(P2P), 실패할 때만 서버 메모리 중계

부록 A4

전송 흐름

검사부터 P2P 전송, 받는 쪽 검증까지 4단계

1단계

발신자 → 서버

검사

파일과 수신자 목록을 보내 수신자별 판정·설명을 받음

2단계

서버

재판정

같은 파일로 다시 판정하고 수신자별 서명 토큰 발급

3단계

발신자 → 수신자

P2P 전송

파일과 토큰을 브라우저끼리 직접 전달

4단계

수신자

검증

서명 · 해시 · 수신자 · 만료 확인 후 다운로드

P2P 실패 시 서버 메모리 중계 (10분, 1회 수신 후 삭제) · 받는 쪽 검증은 동일

부록 A6

기술 결정 (1) 측정으로 고른 것

같은 데이터로 비교해서 결정한 항목

결정	선택	근거
정형 탐지	정규식 + 문맥	정밀도 69% → 96%
문장 판단	LLM, 후보 문장만	재현율 0% → 100%, 문서당 AI 호출 1회
조항 검색	BM25 + 조 제목 필터	Recall@3 90% → 100% (임베딩과는 비교 안 함)
모델 구성	판단·설명 모델 분리	설명 대기 35초 → 2.4초
로컬 모델	qwen3:8b + exaone3.5:7.8b	3개 모델 비교, 14b가 더 느리고 판단도 낮음
OCR	Tesseract 5 + 전처리	전처리 효과만 측정: 개인정보 인식 3~4/6 → 6/6

부록 A6

기술 결정 (2) 조건과 논리로 고른 것

측정 대신 폐쇄망·보안·비용 조건으로 결정한 항목

결정	선택	이유
OCR 엔진	Tesseract	무료, 인터넷·GPU 없이 CPU로 동작 · 클라우드 OCR은 외부 전송, 딥러닝 OCR은 GPU 필요
서명 방식	ECDSA P-256	브라우저가 공개키로 검증 가능 · HMAC은 브라우저에 비밀키가 필요
전송	P2P + 메모리 중계	서버에 파일을 남기지 않음 · 미접속 수신자 대비
서버	Python FastAPI	문서 처리·AI 라이브러리가 Python에 많음, 비동기 WebSocket
화면	HTML/JS (프레임워크 없음)	WebRTC·WebCrypto가 브라우저 기본 기능, 빌드 과정 불필요
배포	Render 무료	카드 없이 외부에서 접속 가능한 HTTPS 주소

부록 A7

원래 기획 대비 변경점

기업 과제 원문에서 바꾼 것과 그 이유

기업 과제 원문	SafeDrop	이유
판단하는 AI Agent	판정은 규칙표, AI는 문맥 판단과 설명	재현·감사가 가능해야 함
브라우저 기반 P2P	P2P + 실패 시 서버 중계 (10분, 1회)	미접속·사내망 제약
(언급 없음)	받는 쪽이 서명 토큰 검증	화면 조작·파일 바꿔치기 방지
(언급 없음)	OCR (스캔 PDF·사진)	멘토·퍼실리테이터 질문 반영
외부 클라우드 불가 기업	시연은 외부 AI, 로컬 LLM 측정과 설치 묶음 준비	시연 환경 제약 · 대상 조건은 로컬로 충족

유지: 대상 기업 · 브라우저 기반 · 사내 규정과 수신자 정보에 따른 허용·마스킹·차단

부록 A8

규정과 사람을 넣는 방법

정보보호팀이 처음 한 번 준비 · AI 추가 학습 불필요

사람

직원 1명 = 이름 · 부서 · 개인정보취급자 여부 · 외부인 여부

규정 문서

조항마다 번호 · 예: [3-2] 개인정보취급자가 아닌 임직원에게는 고유식별정보를 마스킹한 사본만 전송할 수 있다

검색 색인

서버가 켜질 때 자동 생성

판정 규칙표 (정보 유형 5 × 수신자 유형 4)

정보 유형	취급자	같은 부서	다른 부서	외부
고유식별	허용	마스킹	마스킹	차단
금융	허용	마스킹	마스킹	차단
연락처	허용	허용	허용	마스킹
민감	허용	마스킹	차단	차단
확인 불가	차단	차단	차단	차단

칸마다 근거 조항이 함께 들어감 · 여러 정보가 섞이면 가장 엄격한 조치